

FACULTY OF COMPUTING & SOFTWARE ENG'G

COURSE TITLE:
FUNDAMENTAL OF SOFTWARE SECURITY
(SEng-7431)

By:Tagel W.(M.Sc.)

Chapter 1
INTRODUCTION TO SECURITY





Outlines

- Introduction to security
- Key Objectives of Security
- Computer Security Challenges
- Security Services and Mechanisms
- Security Attacks
- Security Techniques
- Model for Network Security
- Software Security

Fundamental of Security

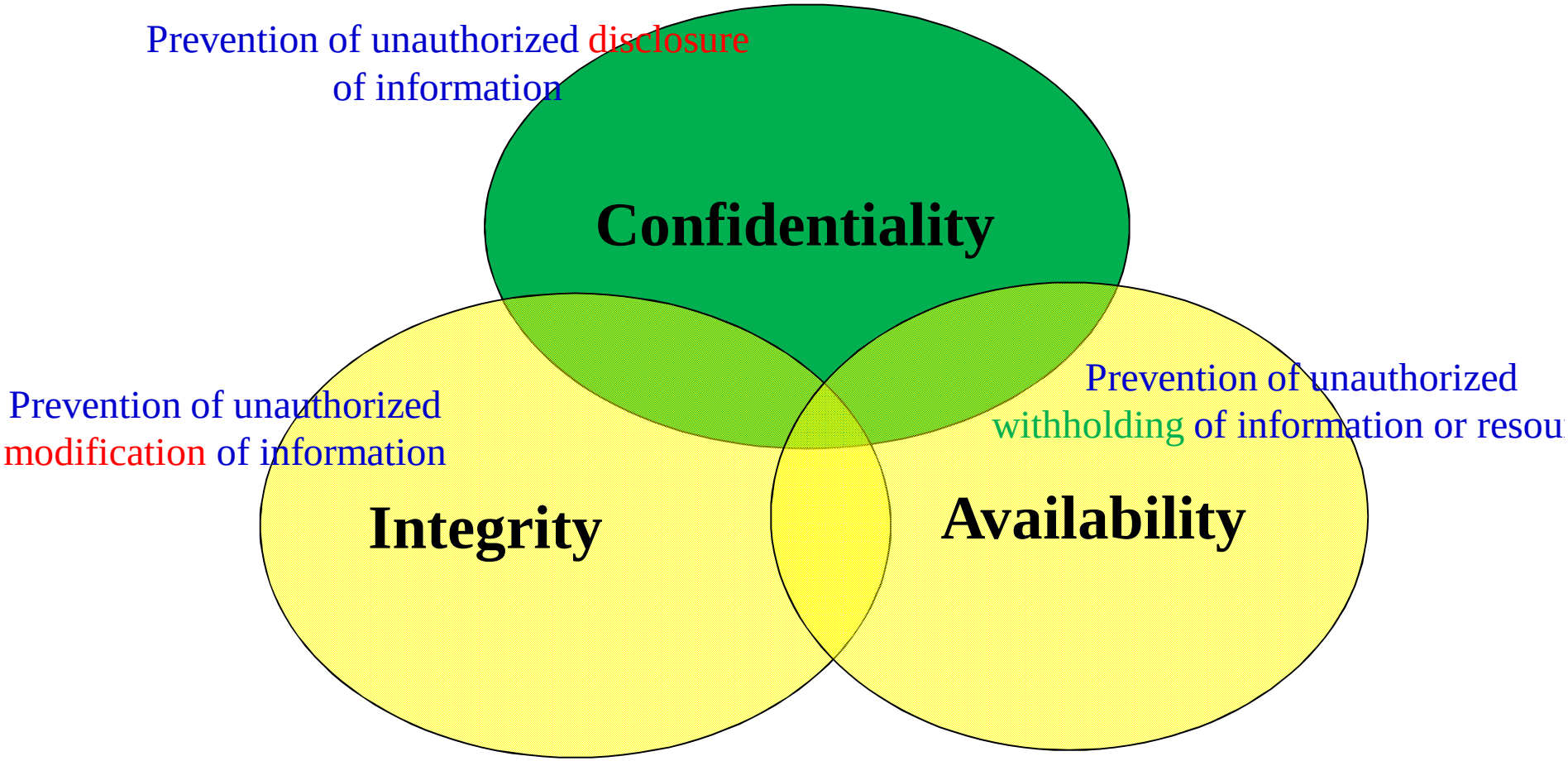
- Security:- prevents unauthorized access to organizational assets (computers, networks, and data).
  - Maintains confidentiality, integrity and availability.
- How ??? using technology, processes and training
- Computer Security:- is broader term contains different security measures to protect computer systems and networks from unauthorized access, unauthorized use, or destruction.
- Process of preventing and detecting unauthorized use of the computer system.

Fundamental of Security

- Components of computer system that needs to be protected are:
- Hardware:- physical part of the computer, like system memory, CPU, peripherals from outside and disk drive etc.
- Firmware:- embedded on the hardware devices
  - Responsible for controlling the basic functions of the device
    - such as booting up and communicating with other software.
    - Use up-to-date with the latest security patches and updates
    - E.g. BIOS
    - how to protect ??? password , full disk encryption.
- Software:- protecting operating system, word processor, internet browser to the user

Fundamental of Security

Computer Security is mainly concerned with three main goals usually called Security Principals or CIA.



Fundamental of Security

Key Objectives of Computer Security

- Computer security is mainly concerned with three main goals which are described here below :
- Confidentiality:- is preventing the disclosure of data to unauthorized parties.
- Keeping identity of authorized parties in sharing and holding data private and anonymous.
- Compromised by cracking poorly encrypted data, Man-in-the-middle(MITM) attacks, disclosing sensitive data.

Fundamental of Security

- Key Objectives of computer Security …
- Standard measures to establish confidentiality include:
  - Data encryption
  - Two-factor authentication
  - Biometric verification
  - Security tokens

- Integrity:- is protecting information from being modified by unauthorized parties.

- Information and programs are changed only in a specified and authorize.

Fundamental of Security

- Key Objectives of computer Security …
- Standard measures to guarantee integrity include:
  - Cryptographic checksums
  - Using file permissions
  - Uninterrupted power supplies
  - Data backups

- Availability:- Ensuring the information and systems are available and accessible to authorized users when needed.
- Data only has value if the right people can access at the right time.
- Information unavailability can occur with security incidents such as DDoS attacks, hardware failures, programming errors, human errors.

Fundamental of Security

- Key Objectives of computer Security …

- Standard measures to guarantee availability include:
  - Backing up data to external drives
  - Implementing firewalls
  - Having backup power supplies
  - Data redundancy

- All cyber attacks have the potential to threaten one or more of the three parts of the CIA triad.

- Confidentiality, integrity, and availability all have to work together to keep the information secure.

Types of Computer Security

1. Information Security:- is protecting sensitive information from unauthorized access or disclosure. E.g. Encryption, access controls

2. Cybersecurity:- protecting digital information from danger

   - Protection of networks, devices, data from unauthorized access or practice of ensuring the CIA triad

3. Application Security:- securing software applications to prevent unauthorized access, modification, or misuse.

- Use protection measures such as secure coding practices, input validation, and session management.

Types of Computer Security

4. Network Security:-is to protect computer networks from unauthorized access, use, or modification.

- It is securing both the software and hardware technologies e.g. firewall, intrusion detection, access control, VPN etc.
- It prevents from negatively affecting users' ability to access or use the network.
- Network security has become increasingly challenging as businesses increase the number of endpoints and migrate services to public cloud.

Types of Computer Security

5. Internet Security:- protecting computer systems and networks from threats that originate from the internet.

- How to make secure??

- By implementing web security measures e.g. secure browsing and filtering, that protect against malicious websites and other internet-based threats

6. Endpoint Security:- securing end devices such as laptops, smartphones, and other endpoints that connect to computer networks.

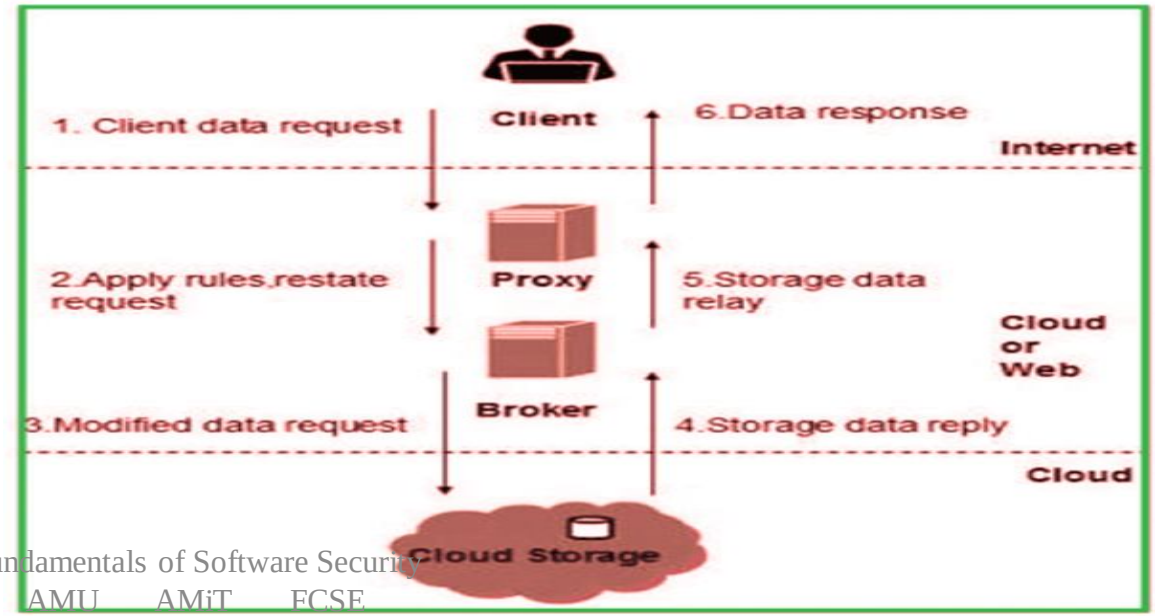
- Apply and monitor endpoint security policies throughout the entire network with small software apps on each managed device.

- E.g. Advance malware protection

Types of Computer Security …

7. Cloud Security:- securing data and applications hosted in cloud environments to prevent unauthorized access or modification.

- Cloud security can help secure the usage of software-as-a-service (SaaS) applications and the public cloud
- security measures includes data encryption, access controls, and identity and access mgmt.



Computer Security Threats

- Computer Security Threat: is any type of activity or event that has potential to harm or compromise security and privacy of computer systems, networks, or users.
- Some Computer Security threats are:

- A computer virus is type of malware that replicates itself by attaching to other programs or files on a system.
- an infected program or file is executed, virus can spread to other files and systems.
- Viruses require human intervention



- E.g. opening an infected email attachment or downloading and running an infected file, to spread.
- The victim's computer will never be able to operate properly at all.

Computer Security Threats

- A computer worm:- is a self-replicating type of malware that spreads through networks and internet without human intervention.
- Exploit vulnerabilities in software or network protocols to spread from one computer to another, causing network disruptions.
- Can infect a large number of systems quickly and can be difficult to detect and remove.



  - E.g. Use up hard disk space because a worm can replicate in great volume and speed.
- Phishing:- type of attack that uses social engineering techniques to trick users into disclosing sensitive information.
  - E.g. passwords and credit card numbers

Computer Security Threats

- Botnet:- a network of computers or devices that are infected with malware and controlled by a malicious actors called a botmaster.
- Can remotely control the bots to carry out sending spam emails, launching DDoS attacks, stealing sensitive data, and spreading malware.
- Cause significant damage to individuals, organizations, and even countries.
  - protection: update driver , anti-spyware, antivirus, firewall etc.
- Rootkit:- type of malicious software that is designed to hide its presence from users and security systems on a compromised computer or device.
- used by attackers to gain and maintain unauthorized access to a system, steal sensitive data

- Protect: keep software up-to-date, use antivirus software, and avoid downloading and from untrusted sources..

Why is Computer Security Important?

- Keystroke logger(keyboard capture):- is a technology used to monitor and record every keystroke made on a computer or mobile device
- It is a very powerful threat to steal people's login credential (username and password)



- Why is Computer Security Important?
- To keep computers and personal information secure and protected.
- To maintain and overall health of computer by preventing viruses and malware which impact on the system performance.

Computer Security Practices

- The common protection of the computer security threats are:
- Secure computer physically
- Install and use reliable, reputable antivirus software
- Activating firewall
- Stay up-to-date software and perform software updates
- Use strong password and change password regularly
- Use Internet with cares and ignore pop-ups drive-by downloads while browsing
- Daily full system scans and
- Backup data regularly

Challenges of Computer Security

- Some common challenges of computer security include:
- Advanced threats are developing new and sophisticated methods to bypass security measures and exploit vulnerabilities of systems.
- Lack of awareness: users are not aware of the risks if do not follow security best practices.
- Complexity of systems: its difficult to implement and manage effective security measures.
- Insider threats: employee can intentionally or unintentionally leak or steal data.
- Resource constraints: Implementing and maintaining effective security measures can require significant resources(time, money, and expertise)
- Human error: e.g. accidentally clicking on a phishing link

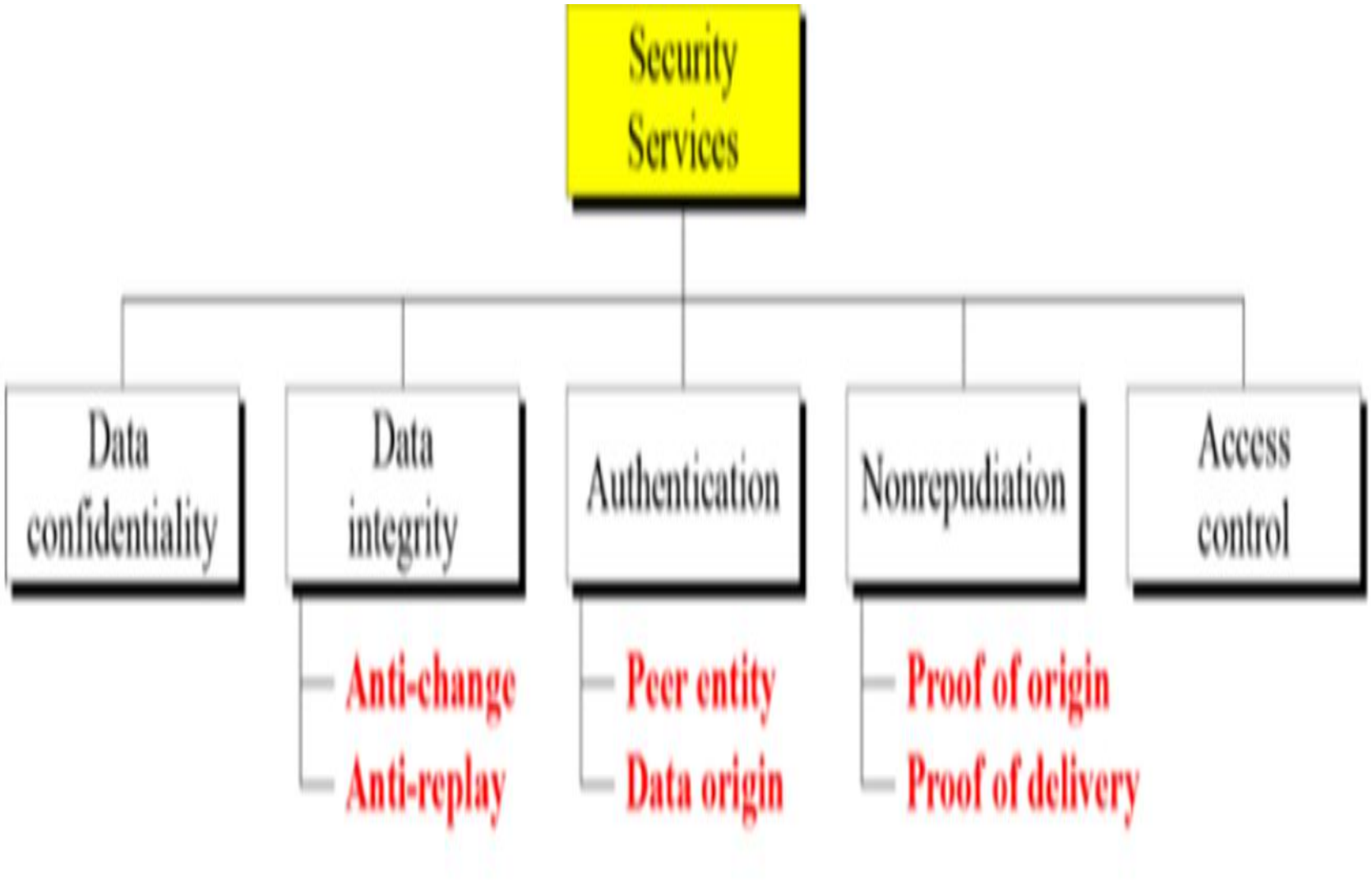
OSI Security Architecture

- X.800 Security Architecture developed by ITU provides a framework for securing computer systems and networks.
- It provided by a protocol layer of communicating open systems to ensure adequate security of the systems or data transfers
- Consider three aspects of information security:
- Security service
- Security mechanism
- Security attack

Security services

- Security services :-are functions that provide protection and security to computer systems and networks.
- are designed to counter security attacks and protect computer systems and networks from threats
- To provide these service one or more security mechanisms is used.

Security services



Security services…

- The classification of security services are as follows:

1.Confidentiality:- ensures the information in a computer system and transmitted information are accessible only for reading by authorized parties.

a) Connection confidentiality:- the protection of all user information on a connection(e.g. TLS or SSL)

b) Connectionless confidentiality:-the security of all user data in an individual data block e.g. authentication

c) Traffic flow confidentiality:- the protection of the information that can be derived from observation(analysis) of traffic flows e.g.VPN

Security services…

2. Authentication:- the process of verifying identity of a user, process, or device allowing access to resources in an information system

- The assurance the communicating entity is the one that it claims to be.

a) Peer Entity Authentication:- verifies the identity of communicating entities. E.g. SSL or TLS

b) Data Origin Authentication:- an assurance that the source of the information is indeed verified.

- How ?? digital signature , hashing etc

Security services…

3. Access Control:- the prevention of unauthorized use of a resource

- This Service controls who to access resource, under what conditions access can occur, and what those accessing resource are allowed to do

4. Non repudiation:- provides protection against one of the entities from denying all or part of the communication.

- It prevents either sender or receiver from denying message transmission or receipt of message

a) Nonrepudiation Origin proof of message authenticity and ensure that the sender cannot deny the message.

b) Nonrepudiation Destination: ensures that the recipient of a message or data cannot deny having received it.

Security services…

5. Integrity:- is designed to secure information from modification, insertion, deletion and rehashing by any entity.

- Data integrity can be used to a flow of message, an individual message or a selected portion inside a message.
- There are various types of data integrity which are :

a) Connection integrity with recovery: ensures that data transmitted over a network connection arrives at its destination intact and has not been modified in transit

   - ✓ To recover lost or damaged data to ensure that the connection remains functional.

Security services …

- data integrity …

b) Connection integrity without recovery :- only detection without recovery.

6. Availability: requires that computer system assets be available to authorized parties when needed.

- It addresses denial-of-service attacks
  - Protection: access control, authentication etc.

Security Mechanisms

- It is mechanism designed to detect, prevent, or recover from a security attack
- Security mechanisms are divided into:

1. Specific security mechanisms and
2. Pervasive security mechanisms.

1. Specific Security mechanism:- a process which is designed to identify, avoid or restore from a security attack.

- The mechanisms are divided into a definite protocol layer, including TCP or an application-layer protocol.

Security mechanisms…

Specific mechanism



Security mechanisms …

- Encipherment:- to the process of applying mathematical algorithms for converting data into a form that is not intelligible.
  - ✓ reversible & irreversible
- This depends on algorithm used and encryption keys.
- Digital Signature: a cryptographic transformation applied to any data unit allowing to prove the source and integrity of data unit are protected against forgery.
- Access Control:- techniques used for enforcing access permissions to the system resources.

Security mechanisms…

- Specific Security Mechanisms…
- Data Integrity: a used to assure the integrity of a data unit or stream of data units.
- Authentication Exchange:- a mechanism intended to ensure the identity of an entity by means of information exchange(TCP)
- Traffic Padding:- protect the confidentiality of data by adding extra data to a communication stream
- Routing Control:- enables selection of particular physically secure routes for certain data and allows routing changes once a breach of security is suspected.
- Notarization:- use of a trusted third party to assure certain properties of a data exchange.

Security mechanisms …

- Pervasive Security Mechanisms:-are not specific to any particular security service
- Trusted Functionality: set of security features and mechanisms that are designed to ensure the integrity and confidentiality of software and hardware systems.
- Includes security feature, e.g. security, secure boot processes, and secure storage mechanisms.
- Security Level: is determined by the strength of the security controls in place, the level of protection provided, and the level of risk that is acceptable to the organization.

Security mechanisms…

- Event Detection:-the process of detecting all the events related to network security e.g. violations of security.
- Security Audit Trail: record of all events and actions occurred within a computer system or network.
- It used to monitor the system for security breaches, provide a history of system activity used for forensic analysis in the event of an incident.
- Security Recovery:- process of recovering from a security breach or incident, such as a cyber attack, data breaches or other security compromise.

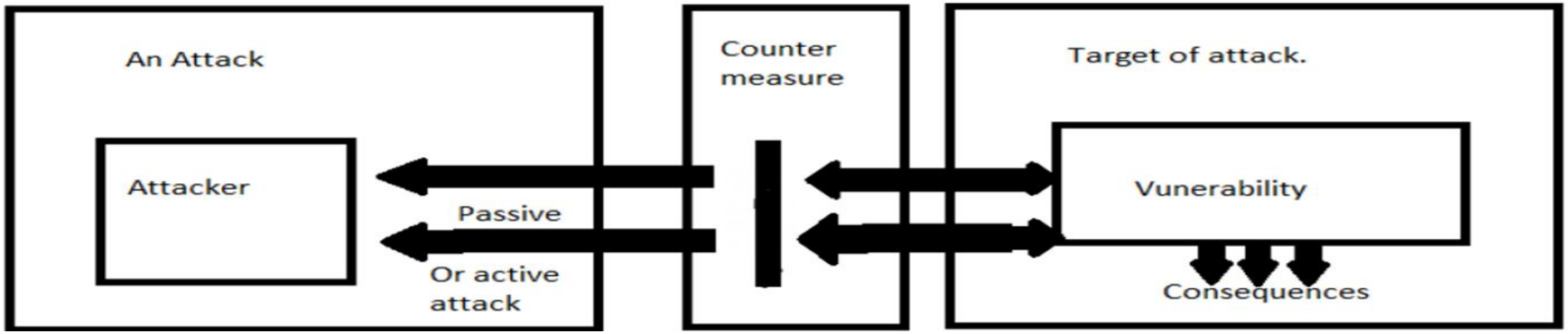
Security Mechanisms and Services

- The relationship between security service and security mechanism

Security Service	*Security Mechanism*
Data confidentiality	Encipherment and routing control
Data integrity	Encipherment, digital signature, data integrity
Authentication	Encipherment, digital signature, authentication exchanges
Nonrepudiation	Digital signature, data integrity, and notarization
Access control	Access control mechanism

Security Attacks

- A malicious attempts to gain unauthorized access to networks, steal data, software computer, disrupt services to computer systems.
- A cyberattack is any offensive operation that targets computer, information systems, infrastructures, computer networks.
- An attacker is a person or process that attempts to access data, system without authorization, potentially with malicious intent



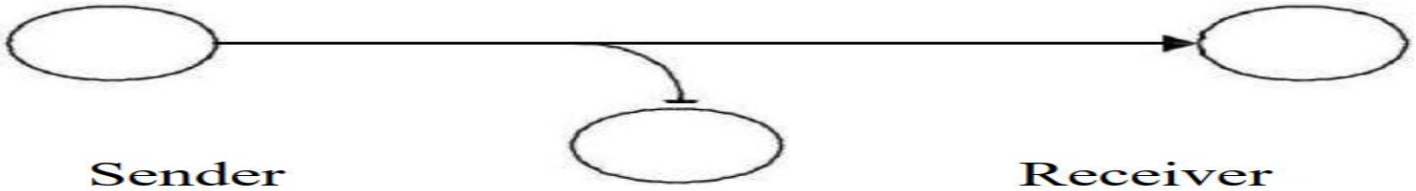
Security Attacks …

- There are four general categories of attacks are:
- Interruption: act of disrupting or halting normal functioning of a computer system or network.
- Attack on availability



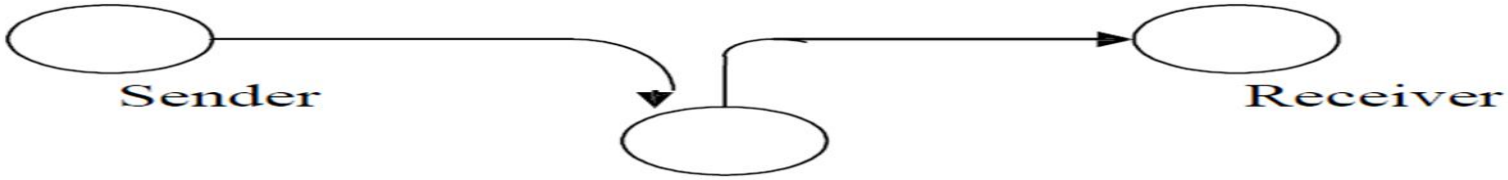


- Interception: capturing or monitoring communication between two parties without their knowledge or consent.
- Attacks on confidentiality.

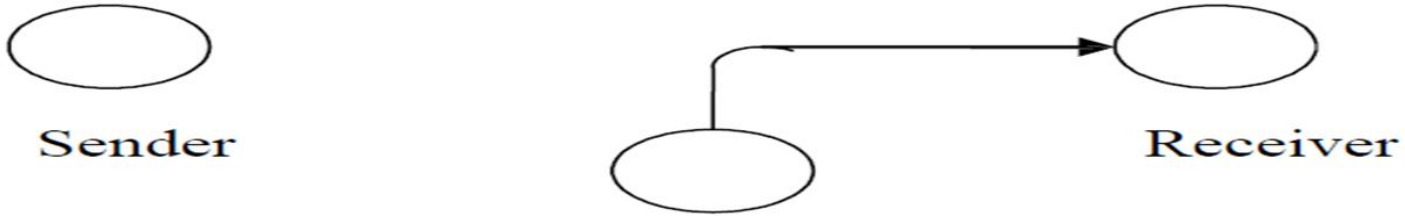


Security Attacks …

- Modification: act of changing or altering data or information without authorization.
- An attack on integrity.



- Fabrication: act of creating or adding false or unauthorized data or information to a computer system or network
- This is an attack on authenticity.



Types of Security Attacks

- There are two types of Security Attacks:

1. Passive Attacks:-an attacker attempts to access information or data without altering or disrupting the normal functioning of a computer system

- The attacker observes the content of messages or copies the content of messages.
- The goal of the opponent is to obtain information that is being transmitted
- It is very difficult to detect because they do not involve any alteration of data.
- Passive attacks are of two types:
  - Release of message contents
  - Traffic analysis

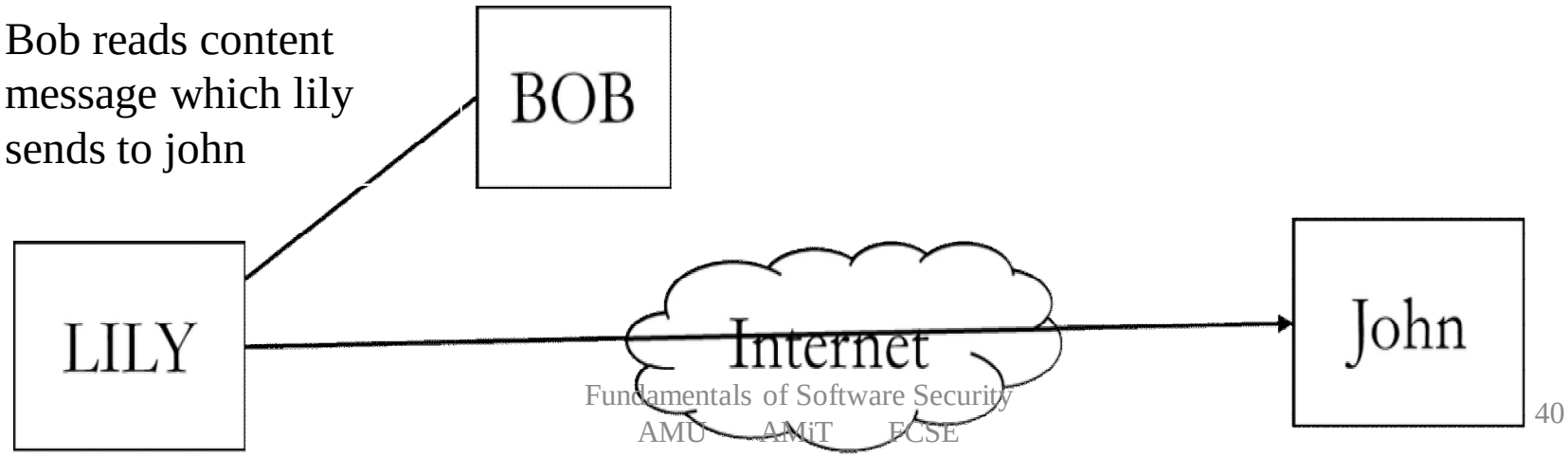
Types of Security Attacks …

- Passive attacks are of two types:

- Release of message contents:- the unauthorized disclosure or exposure of the contents of a message or communication.

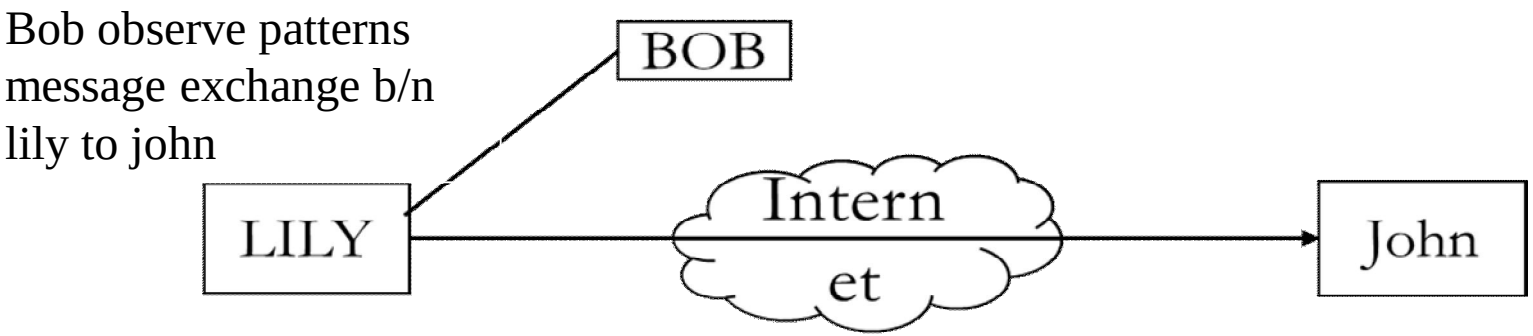
- The intruder intercepts the message and confidentiality of the message is lost.

- Telephonic conversation, an electronic mail message or a transferred file may contain sensitive or confidential information.



Types of Security Attacks

- Passive attacks are of two types…
- Traffic analysis:- analyzing patterns the traffic, determine the location and identity of communicating host and observe the frequency and length of messages being exchanged
- All incoming and outgoing traffic of the network is analyzed, but not altered



- Passive attacks prevention by encryption

Types of Security Attacks…

- Active attacks:- the attacker efforts to change or modify the content of messages.
- It is a danger for Integrity as well as availability
- Here the system is always damaged and system resources can be changed.
- The most important thing, in an active attack, Victim gets informed about the attack.
- Types of Active Attacks
  - Masquerade
  - Modification of messages
  - Replay
  - Repudiation
  - Denial of Service(DoS)

Types of Security Attacks…

- Types of active attacks…

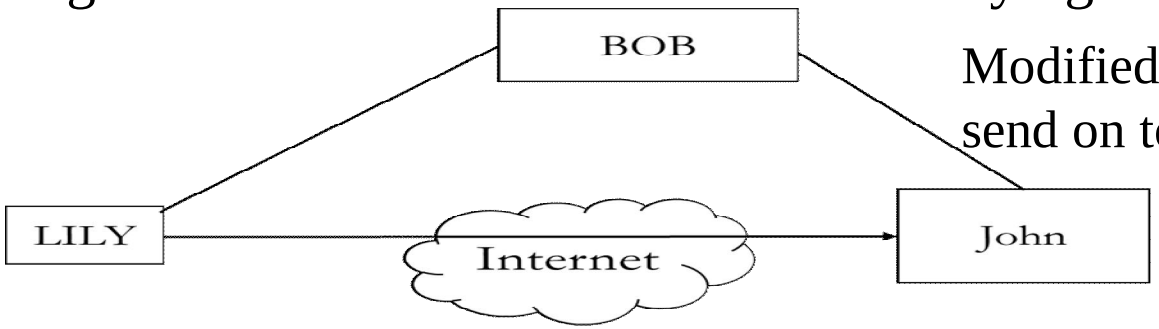
- Masquerade:- an attacker impersonates a legitimate user or system in order to gain unauthorized access to a computer system or network or to carry out malicious activities.
- Can involve using a fake username or password, or other falsified credentials.
- Can be insider or outsider of the organization connected to a public network.
- an insider attack, a masquerade attacker gains access to the account of a legitimate user either by stealing the victim's account ID and password, or using a keylogger.

Types of Security(active) Attacks…

- Masquerade …
- An Outsider by exploiting a legitimate user's laziness and trust.
- E.g. if a legitimate user leaves the terminal or session open and logged in, a co-worker may act as a masquerade attacker
- Finding vulnerable authentication that can trigger a masquerade attack, as it helps the attacker to gain access much more easily.
- As the attackers gain access and gets into all the organization's critical data and can delete or modify, steal sensitive data, or alter routing information and network configuration.

Types of Security Attacks…

- Types of active attacks…
  - Modification of messages:- portion of an authorized message is altered or delayed or reordered to produce an unauthorized effect.
  - It could involves in modifying a packet header address for the purpose of directing to an unintended destination or modifying the user data

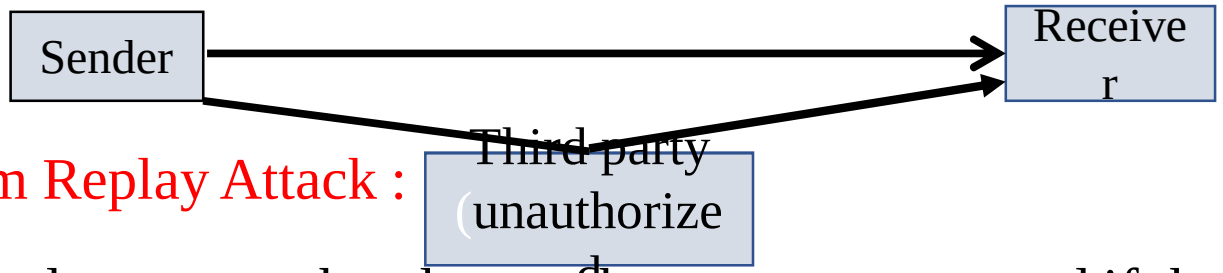


Modified the message and send on to John from LILY

  - Repudiation:- done by either sender or receiver.
    - Sender or receiver can deny later that he/she has sent or received a message.
    - E.g. when a person signs a contract with another party but later denies that they ever agreed to the terms of the contract.

Types of Security Attacks…

- Types of active attacks…
- Replay attack:- the interception and retransmission of data packets between two systems.
- an attacker intercepts a data packet that contains sensitive information, such as a password or authentication token, and then retransmits that packet at a later time to gain unauthorized access to a system.



- Prevention from Replay Attack :
- Timestamp : used to ensure that data packets are not accepted if they are too late.
- Session key : key can be used only once per transaction and cannot be reused.

Types of Security Attacks…

- Types of active attacks…

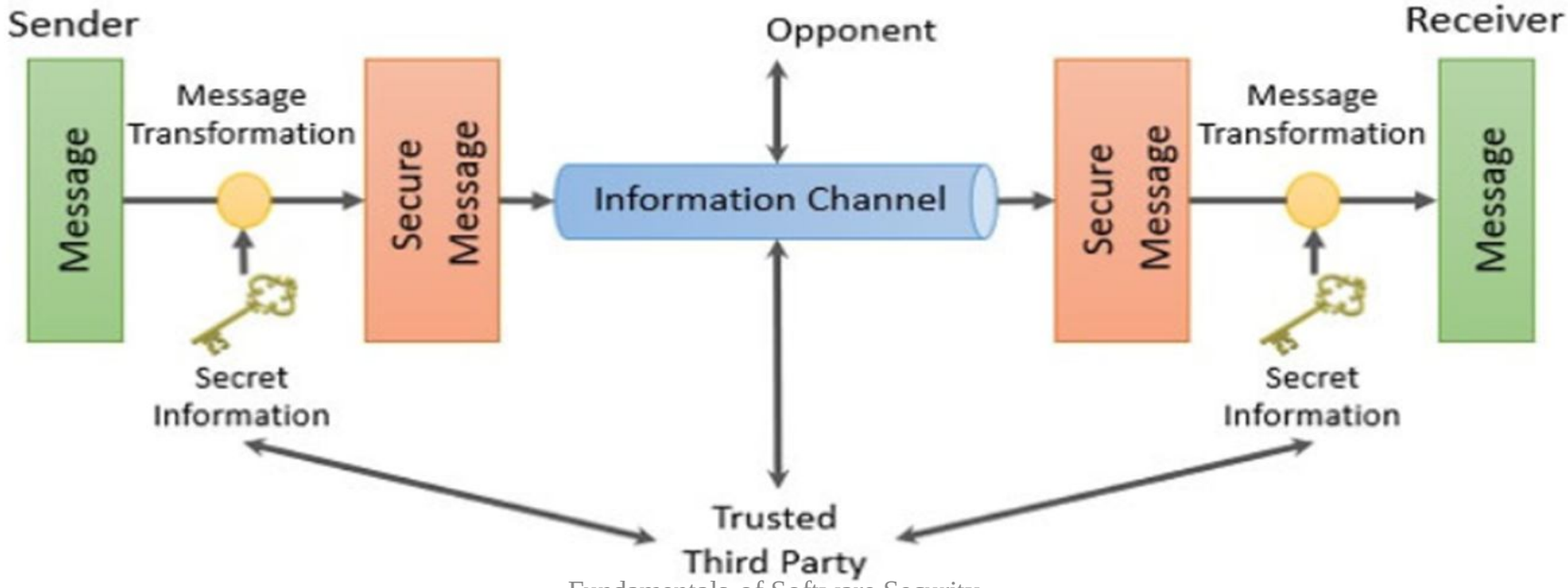
- Denial of Service (DOS):- an attacker attempts to disrupt the services provided by a host.
- Deny the intended users to access the host from the Internet.
- It is accomplished by flooding the targeted machine or resource with excess requests in an attempt to overload systems and prevent legitimate requests from being fulfilled.
- It can cause computers and routers to crash and links to bog down.
- It prevents the normal use of communication facilities.

Security Techniques

- There are different types of Security Techniques. Some may includes:
  - Shield firewalls, virus scanner
  - Access controls, VPNs
  - Protocol IPsec's, SSL/TLS
  - Intrusion detection systems, IDS
  - Training awareness
  - Redundancy backup, encryptions, hashes, digests and etc.

Model for Network Security

- It show how security service has designed over network to prevent the opponent from causing a threat to confidentiality or authenticity of information being transmitted through the network.
- It is how messages are shared between sender and receiver securely over the network.



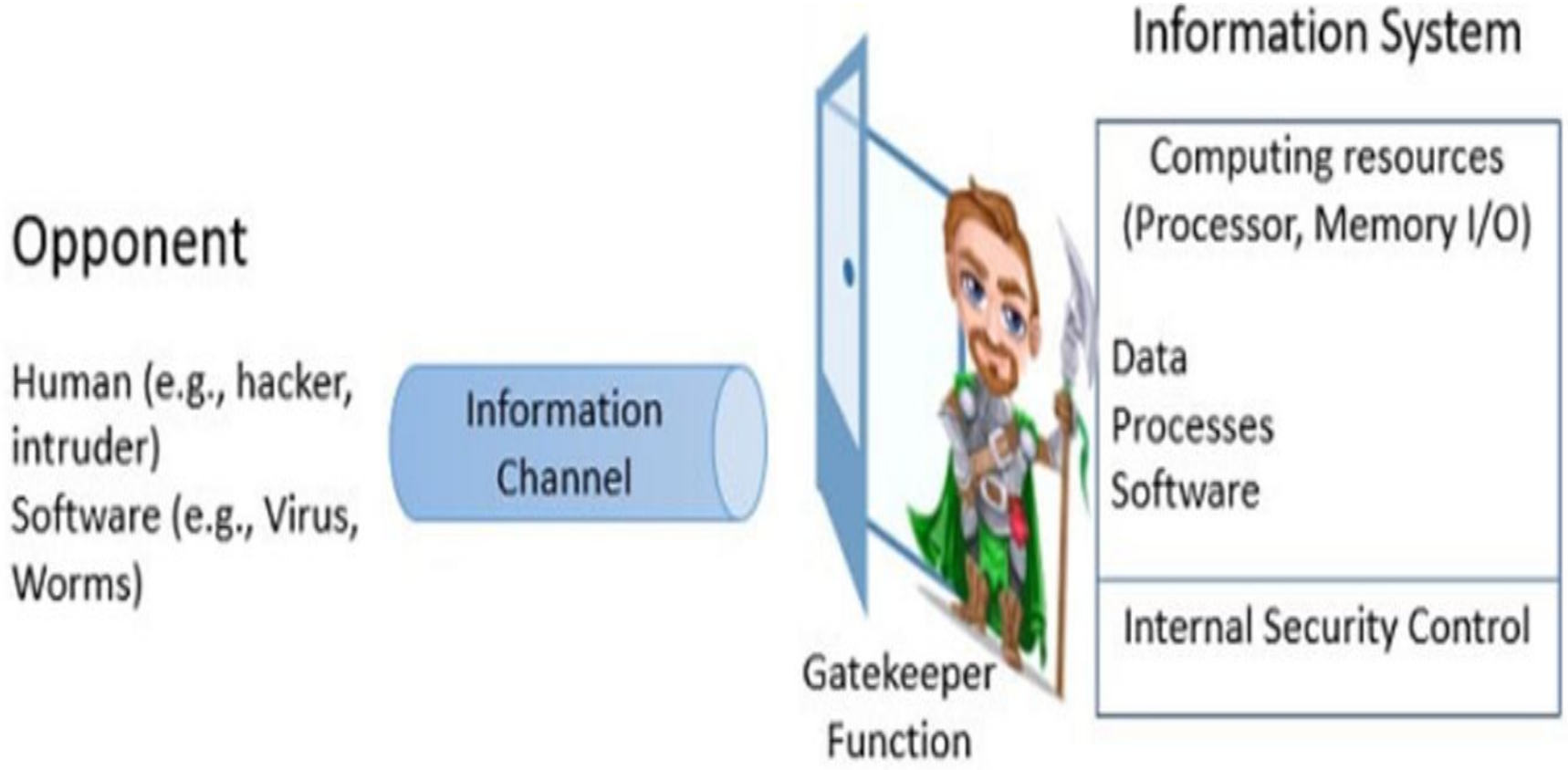
Model for Network Security

- Trusted third party:- is responsible for distributing the secret information to the two principals while keeping from any opponent (e.g. banking server).
- There are four major tasks in designing a particular security service:

1. Design an algorithm for security-related transformation.
2. Generate secret information to be used with the algorithm.
3. Develop methods for distribution and sharing of secret information.
4. Specify a protocol to be used by the two principals that use of security algorithm and secret information to achieve a security service.

Model for Network Security

- Network Access Security Model:- is designed to secure the system from unwanted access through the network.



Model for Network Security

- Network access security model…

1. Hacker: one who is interested in penetrating into the system (ethical or unethical)
2. Intruders: attackers intend to do damage to the system or obtain information from the system which can be used to achieve financial gain.

- This leads two kinds of risks:

1. Information threat (e.g. modification of data)
2. Service threat (e.g. disable access)

- Two ways to secure the system from an attacker

- Gatekeeper function (login-ID and passwords or firewall) keep away unwanted access.
- Internal control: detect the unwanted user trying to access the system by analyzing system activities e.g. Antivirus.

Model for Network Security

"The most secure computers are those not connected to the Internet and shielded from any interference"



Software Security

- Software Security: is a measures and techniques used to ensure that software systems are secure and protected against unauthorized access, use, or modification.
- It is an essential aspect of computer security and critical for ensuring the confidentiality, integrity, and availability of sensitive data.



Software Security

- Majority of security incidents result from defects in software design or code.
- Attackers exploit the security holes left out by software developers.

- Post-deployment security is more popular than pre-deployment because:
  - Easily understood by administrators
  - Difficult to get security "assurance" from vendor
    - Vendors are obsessed by "time-to-market"
    - Difficult to know/tailor security requirements for general purpose software

Software Security

Risk Management

- Software security as risk management!
- Risk: "The possibility of suffering harm or loss"
- Management: "The act or art of treating, directing, carrying on, or using for a purpose"
- Risk Management is the process concerned with
  - identification, measurement, control and minimization of security risks in information systems to a level that commensurate with the value of the assets protected

Software Security

Risk Management …

- Methods of risk treatment:
  - Mitigate or suppress
  - Accept
  - Transfer (insurance)
  - Ignore (poor – often used)
- Types of countermeasures
  - Preventive
  - Detective
  - Corrective
- In case of risk acceptance
  - Request documented justification
  - Get formal approbation (sign-off) by senior management
  - Have the decision reviewed after a year

Software Security

Software Risk Management

- Use a high quality software engineering methodology
- Risk analysis should be performed at every stage of the software development life cycle(SDLC):
  - Requirement analysis
  - Design
  - Coding
  - Testing, etc

Software Security

Selecting Technologies

- Languages
  - The choice of a programming language has an impact on how secure the software will be
  - Security problems are common for some languages
    - C, C++ => Buffer overflow
    - Java => Exception handling, etc
  - High level languages hide what they are doing (ex. Swapping to disk)
    - The programmer doesn't know that
    - The attackers may use this

Software Security

Selecting Technologies…

- Operating systems
  - Typical Operating Systems (Windows, Linux, etc) have
    - Authentication of users
    - Resource access control (authorization & limitation)
      - *Memory, Files, etc.*
    - Integrity of shared resources
  - Operating systems have different levels of security

Software Security

Selecting Technologies…

- Authentication technologies
  - Password
  - Host-Based (ex. IP)
  - Physical token (ex. Smartcard)
  - Biometrics

Software Security

Open Source or Closed Source

- Free Software
  - Freedoms to use, copy, study, modify and redistribute both modified and unmodified copies of software programs
- Open Source Software (OSS)
  - Similar in idea to "free software" but slightly less rigid
- FOSS/FLOSS
  - Free/Libre/Open-Source Software is the name used by those who wish to be inclusive

Software Security

Open Source or Closed Source …

- OSS provides a number of benefits to security, because security by obscurity does not work!
- Hackers may not always need the code to find security vulnerabilities
- Reverse engineering is possible
  - Disassemblers
  - Decompilers

Software Security

Open Source Software(OSS)

- OSS model gives some economic incentives for others to review your code
  - Users of the software may want to check the security of the software
  - Some users who want to make changes to the software will look at the software
- However, you cannot be sure of the security of the software just because it is OSS
  - Many vulnerabilities are hard to detect
  - Some software sources are difficult to read
  - Some software sources don't have many readers
- Additional vulnerabilities!
  - Code scanning can be used by attackers!

Software Security

Auditing Software

- Auditing software's functionality is a complex activity
- Auditing software's security is even more complex
- Most software development companies consider security of their software only once or twice during the development cycle
- Software teams prefer to use their time mainly on developing new functionalities that can be seen
- Ideally every software project should have an independent security person or team
- A good time for an initial security analysis is after the preliminary design
  - You can avoid security risks in the architecture of your software with limited cost
  - You will be more willing to make major changes

Software Security

- Some of Software Security measures and techniques include:
  - ✓ Authentication and access controls:
  - ✓ Encryption
  - ✓ Secure coding practices
  - ✓ Penetration testing
  - ✓ Incident response planning

End of Chapter-1

Qn. if Any???

